

SRC-0031 - Systematic analysis of automated threat modelling techniques

Domanda standard 1/4 - Qual e il problema di ricerca e qual e il contributo?

Identita, RQ, protocollo SLR e confini della review

Identita	Granata e Rak, Software Quality Journal 32, 125-161 (2024).
DOI	10.1007/s11219-023-09634-4
Evidenza	Systematic literature review + confronto illustrativo su WordPress.
Corpus	55 studi inclusi; strumenti emersi dalla SLR e integrazione manuale.
Classificazione	model_required: automazione dopo la costruzione del modello.

Problema

Il threat modelling manuale e costoso e dipende da competenze specialistiche. La fonte studia come automatizzare la selezione delle minacce e quali strumenti supportano tale processo.

Domande di ricerca

- RQ1: metodologie che producono automaticamente un threat model.
- RQ2: strumenti open source che supportano le metodologie automatizzate.

Contributi

- SLR di tecniche, classificazioni, regole e strumenti.
- Descrizione di Microsoft, Threat Dragon, SLA-generator e PyTM.
- Confronto dello stesso caso WordPress in quattro strumenti.

Flusso dichiarato

465 record nel testo (466 in Table 2)
-> 115 dopo abstract screening
-> 55 inclusi dopo full-text review

Limiti del protocollo

- Nessun quality assessment o risk-of-bias reportato.
- Nessun inter-rater agreement reportato.
- Esclusi studi manuali, domain-specific, non inglesi o non scaricabili.
- La review non e dedicata al model-based security testing.

Uso DDTA

La fonte e centrale per definire il confine model-to-candidate-threat. Non dimostra la trasformazione automatica documentazione-to-model.

SRC-0031 - Systematic analysis of automated threat modelling techniques

Domanda standard 2/4 - Quali sono gli artefatti iniziali e come vengono rappresentati?

Modelli, classificazioni, regole di selezione e cataloghi

Input operativo

```
typed system model
+ labels / properties / relationships / protocols
+ threat catalogue and rules
-> candidate threats
```

Rappresentazioni nei 55 studi

DFD	14 standard + 6 estesi
Grafi	8 MACM + 4 proprietari
Architettura	6 modelli proprietari
Asset list	7
UML / altro	3 UML + 2 brainstorming + 5 minori

Classificazioni

- STRIDE: 30 studi; CIA e varianti: 13.
- Extended STRIDE: 4; LINDDUN: 3; CAPEC: 2.
- Altri usano regole Prolog, threat tree/path/matrix o linguaggi propri.

Selezione automatica

- Label-based: 19; relationship-based: 11; STRIDE-based: 7.
- Rule/pattern-based: 5; propagation: 4; STRIDE/LINDDUN-to-DFD: 3.

Quattro strumenti

Microsoft	DFD proprietario; minacce sulle relazioni; cataloghi proprietari.
Threat Dragon	DFD; nodi e flussi; proprietà, custom threat, status e priority.
SLA-generator	MACM; asset type, relation, protocol, propagation e NIST controls.
PyTM	Python model; genera DFD, sequence diagram e candidate threat.

Confine documentation-first

Il modello viene costruito e annotato dall'utente. La documentazione può informare il modeller, ma non è l'input diretto valutato dall'automazione.

SRC-0031 - Systematic analysis of automated threat modelling techniques

Domanda standard 3/4 - Come funzionano traceability, change, automation e ruolo umano?

Derivazione, provenance, continuous rerun e review

Traceability osservata

```
model element / relationship
-> type + properties + protocol / role
-> catalogue entry + selection rule
-> candidate threat
-> mitigation / control
```

Automazione reale

- Catalogue lookup e rule matching.
- Generazione di report, DFD o sequence view in alcuni strumenti.
- Ricalcolo dopo modifiche al purpose-built model, es. PyTM.

Ruolo umano residuo

- Costruire il modello, scegliere scope e tipologie.
- Inserire properties, protocolli, controlli e custom threat.
- Mantenere cataloghi e regole.
- Revisione, deduplica, plausibilit , priorit  e disposition.

Continuous threat modelling

PyTM pu  applicare controlli al modello e rigenerare il threat model. Questo supporta rerun ripetibili, ma non prova sincronizzazione automatica con documenti, architettura o codice applicativo.

Controlli mancanti

Provenance	Nessuna source-document provenance assertion-level.
Versioning	Versione di catalogo e rule set non governata nel confronto.
Uncertainty	Confidenza e contraddizioni non modellate.
Review	Nessun reviewer agreement o accepted-finding yield.
Change	Nessuna stale detection o change-impact evaluation.

Disciplina DDTA

```
generated candidate != accepted finding
rerun capability != synchronized evidence
source-code model != source-code analysis
```

SRC-0031 - Systematic analysis of automated threat modelling techniques

Domanda standard 4/4 - Quali sono risultati, limiti e rapporto con DDTA/overlay?

Confronto WordPress, incoerenze, plugin boundary e gap

Confronto finale

SLA-generator	84 threat; nodes; granularita variabile.
Microsoft	88 threat; arcs/relationships; granularita alta.
Threat Dragon	30 in Table 19, 31 nel testo; nodes + arcs; bassa.
PyTM	97 nel confronto, 91 nella sezione dedicata; Python elements; alta.

Interpretazione consentita

Tool diversi producono liste non comparabili per solo conteggio: cambiano asset, scope, catalogo, regole e granularita. Il caso non misura precision, recall o completezza.

Limiti principali

- Un solo caso semplice, adattato manualmente a ogni tool.
- Nessuna ground truth indipendente o ranking sperimentale.
- Incoerenze 466/465, 31/30 e 91/97 non risolte.
- Tool inventory incompleto e time-sensitive.
- Dataset disponibile su richiesta, non package pubblico direttamente collegato.

Plugin contract DDTA

Projection	Schema e versione del modello richiesto.
Knowledge	Catalogue ID/version e rule-set ID/version.
Activation	Asset, relazione, proprieta e regola che attivano il candidato.
Lifecycle	candidate -> accepted/rejected/deferred/duplicate -> rerun.
Evaluation	Precision, recall, reviewer effort, accepted yield e maintenance cost.

Gap

Resta aperto il percorso governato documentazione-to-neutral-model e una review dedicata al model-based security testing, con model-to-test generation, oracle ed evidenza sull implementazione.